

## OPAUDIT 020 - The security fix that disconnected the skins

|                       |                                                                                                                                                                                                                                                                                                              |
|-----------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Audit ID</b>       | 2026-10-05-020                                                                                                                                                                                                                                                                                               |
| <b>Report date</b>    | 2026-10-05                                                                                                                                                                                                                                                                                                   |
| <b>First observed</b> | Repeated live presentation and routing regressions after the September 28 skin execution-boundary migration; consolidated as one incident on October 5 after GAME ON, TILEZ, AURORA, JIVE TURKEY, and imported SMACKTALK content exposed missing replacement contracts.                                      |
| <b>Theme</b>          | The security decision was right. The migration was not complete. Executable behavior was removed from skins without first inventorying, rebuilding, and proving every bounded CMS-to-skin contract that had supplied the visible site.                                                                       |
| <b>Surfaces</b>       | Schema-v2 public skins; strict public controllers; route compatibility; saved appearance settings; shared assets and components; SMACKPRESS imported content; skin packaging; CMS and skin release sequencing.                                                                                               |
| <b>State</b>          | <b>OPEN</b> Recovery candidate CMS 0.7.819D and GAME ON 0.1.24 pass local tests. Packaging, deployment, and live acceptance remain required. Whole-fleet parity is not claimed.                                                                                                                              |
| <b>Human impact</b>   | Approximately two weeks of recovery work less than one month before closed beta, damaged trust and morale, lost sleep, and severe autism-related distress reported by the owner, including feeling physically sick. Repeated model-capacity failures prolonged the recovery despite available account quota. |
| <b>Reporter</b>       | Sean identified and repeatedly reproduced the live failures. Codex reconstructed the repository evidence and wrote this report. Model attribution for earlier individual changes remains unproven unless a session record establishes it.                                                                    |
| <b>Related</b>        | SECAUDIT 059 (skin execution boundary), SECAUDIT 060 (migration-integrity follow-up), pre-migration reference v0.7.772D, controller migration beginning at <code>c9eb3a9e</code> .                                                                                                                           |
| <b>Publication</b>    | Owner-gated. The report is intentionally candid; publish only after the recovery is deployed, independently reviewed where required, and the evidence table is completed.                                                                                                                                    |

### 1. SUMMARY

SnapSmack correctly decided that skins must not own database access, request routing, writes, remote calls, or reusable application behavior. The implementation treated that boundary as a removal exercise instead of a contract migration. Old skin code was stripped out and generic replacement layouts were installed before every route, setting, component, asset hook, and interaction had a central replacement and a parity test. Security gates proved that authority was gone. They did not prove that the site still worked.

The predictable result was a long sequence of releases that each restored another missing connection: backgrounds, opacity, navigation, search, complete feeds, image links, static pages, Blogrolls, footers, post

counts, saved hero images, clean routes, and skin-specific presentation. The owner was repeatedly told that a repair was done, then found the next regression on the live site. This was an operational failure, not a collection of unrelated cosmetic defects.

## 2. WHAT FAILED

| Failure                                                 | Evidence                                                                                                                                                                                                                                                                                                                                           | Consequence                                                                                                        |
|---------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------|
| No complete pre-migration contract inventory            | Pre-migration GAME ON, AURORA, PARADE, and JIVE TURKEY each had roughly twelve presentation templates/partials. The replacement process produced one generic <code>layout.php</code> per skin. The read-only parity diagnostic later found 646 candidate CSS hooks that existed before migration, remained referenced, and were no longer emitted. | Necessary presentation behavior vanished even though the new security boundary itself passed.                      |
| Tests proved containment, not parity                    | Migration/parity suites passed while live skins lacked backgrounds, controls, routes, images, Blogroll styling, footers, and viewer behavior. A route audit found 45 declared-route fallthroughs across 12 skins.                                                                                                                                  | Green gates were incorrectly treated as evidence that the visible product survived the migration.                  |
| Generic replacements crossed independent skin contracts | Repository history contains mechanical grid, public, and SMACKTALK restoration scripts and generic replacement commits <code>6cab3a9c</code> , <code>2fe6d73d</code> , and <code>a28749e5</code> .                                                                                                                                                 | Distinct skins were changed as a batch without route-by-route and setting-by-setting acceptance evidence.          |
| Release completion was declared too early               | From 0.7.773D through 0.7.816D, dozens of development tags and many commits named <i>Restore</i> followed the migration. New omissions were repeatedly found only after packaging or live deployment.                                                                                                                                              | The fleet became the parity test environment, multiplying recovery work and owner stress.                          |
| Version order was not respected                         | TILEZ 0.2.59 was packaged and installed while 0.2.58 had not been deployed, despite the owner repeatedly requiring strict sequence. The owner also reported having to finish and deploy CMS 0.7.817D after the assistant stalled, then deploy 0.7.818D.                                                                                            | The version ledger stopped being a trustworthy statement of what had been seen, installed, and verified.           |
| Communication increased rather than reduced load        | The owner repeatedly had to distinguish CMS defects from post data, skin defects from shared assets, and source changes from deployed behavior. Repeated capacity errors interrupted the same recovery thread.                                                                                                                                     | The person already doing acceptance testing also had to supervise scope, sequence, and basic state reconstruction. |

## 3. REPRESENTATIVE REGRESSIONS

- SMACKPRESS-imported images lost their larger-image/lightbox association, and a repair initially targeted the wrong layer instead of the imported post contract.
- TILEZ images widened outside their original footprint on hover; its configured standard footer was present but hidden by a shared drawer controller that claimed the same generic identifier.
- GAME ON lost animated framed-image state, direct photograph routing, background content on secondary pages, styled Blogroll and About presentation, saved About imagery, ordinary footer flow, and the distinction that its landing page already is its archive.
- AURORA's engine remained registered but its intended visibility and post-viewer relationship were not adequately acceptance-tested. JIVE TURKEY's suspected scrim regression was investigated and not confirmed; the saved value was zero.
- Legacy public links and configured menu records continued to use `?view=` and PHP filenames rather than clean owner-facing paths such as `/diary` and `/blogroll`.

## 4. ROOT CAUSE

---

**The project optimized for the absence of forbidden code and failed to specify the presence of required behavior.** A skin-security migration has two acceptance conditions: the old authority must be gone, and every legitimate result that authority used to produce must arrive through a bounded central contract. Only the first condition had a strong gate.

**The work was released in fragments before a representative fleet matrix was complete.** A source test, a DOM token, or one repaired site was repeatedly allowed to stand in for live route and interaction parity. That made each release another discovery step instead of a controlled rollout.

**The release process did not honor the owner's sequential constraint.** This was not harmless bookkeeping. Strict order is both a technical traceability requirement and an accessibility requirement for this owner. Repeating the violation after it had been explicitly explained materially worsened the incident.

## 5. CORRECTIVE ACTIONS

---

1. For every skin family, maintain a pre-migration ledger of routes, settings, emitted structure, shared assets, interactions, and saved-value behavior. Each item must be classified as restored, intentionally retired with owner approval, or still open.
2. Test both halves of every security migration: forbidden authority is absent; required output and behavior are present. A security ratchet alone is never a parity gate.
3. Require browser acceptance for landing, detail/modal, static page, Blogroll, archive semantics, navigation, footer, responsive behavior, and the skin's defining interaction before publishing a skin recovery.
4. Keep releases sequential: create N, package N, deploy N, verify N, then and only then create N+1. A skipped build requires the owner's explicit recorded cancellation; an agent cannot infer it.
5. Separate diagnosis, source repair, package publication, installation, and live verification in every status report. Never use “fixed” when only source tests have passed.
6. Do not bulk-rewrite forkable skins. Shared behavior belongs in audited CMS assets and bounded view models; each skin's presentation remains independently reviewed.

- Record the human cost and accessibility consequences in incident closeout, not only the code delta and test count.

## 6. CURRENT RECOVERY EVIDENCE

---

| Item               | State          | Evidence                                                                                                                                            |
|--------------------|----------------|-----------------------------------------------------------------------------------------------------------------------------------------------------|
| CMS candidate      | Locally tested | Exactly 0.7.819D; 162 PHP regression programs pass, 0 fail; focused route and security-ratchet suites pass; diff integrity passes.                  |
| GAME ON candidate  | Locally tested | Exactly 0.1.24; presentation-only template; bounded page hero, Blogroll, secondary-page background/count, and standard footer reconnections.        |
| TILEZ              | Unchanged      | Remains 0.2.59. The clean-route and idempotent import-repair work is CMS/tool-owned.                                                                |
| Security boundary  | Gate passes    | A draft template-side validation change was rejected by the fleet ratchet before release; validation was moved to core and the ratchet then passed. |
| Live deployment    | Open           | No 0.7.819D or GAME ON 0.1.24 package has yet been installed or verified at the time of this draft.                                                 |
| Whole-fleet parity | Open           | Neither this candidate nor this report represents all remaining skin findings as closed.                                                            |

## 7. CLOSURE GATE

---

This audit closes only after CMS 0.7.819D and GAME ON 0.1.24 are packaged in order, installed on the intended targets, and live-verified for the routes and interactions in this incident; the formal security follow-up is independently reviewed; the remaining fleet parity ledger has an owner-approved disposition; and no later version is created to hide an incomplete earlier one.

## 8. PLAIN ADMISSION

---

We made a necessary security change in an unsafe operational way. We removed code from skins before proving that the CMS supplied everything those skins legitimately needed. We relied on tests that could pass while sites were visibly broken. We released too many partial repairs, broke version order after being told not to, and left the owner to find and supervise regressions that should have been caught before deployment. The resulting loss of time, trust, and wellbeing was avoidable.